

Table of Contents

PART 1: COMPANY GOVERNANCE, ERP ARCHITECTURE & CROSS-CUTTING RULES

Zarewa Aluminium and Plastics Ltd — System of Operations v3.0

Applies to: All staff, IT administrators, external auditors

System modules: Platform-wide

1. INTRODUCTION

1.1 Scope

This section establishes the governance framework within which all Zarewa business operations are conducted through the integrated ERP system. It covers company identity, organisational structure, technology architecture, authentication and security controls, branch data isolation, document standards, approval thresholds, audit requirements, and the cross-cutting business rules that apply regardless of department.

Every staff member — from the sales officer creating a quotation in Kaduna to the production manager completing a job in Yola — operates within the boundaries defined here. Department-specific procedures in SOP-01 through SOP-10 build upon this foundation.

1.2 Authority

The Managing Director (MD) holds ultimate operational authority. The Board of Directors, through the Chairman and CEO, exercises strategic oversight via the Executive Command Centre. Day-to-day system administration is delegated to the System Administrator (admin role). Financial period control rests with the Accountant / Head of Accounts (finance_manager role).

1.3 Compliance Obligation

All staff are required to:

1. Use the ERP for every business transaction — no parallel paper-only processes for items the system tracks.
2. Operate only within their assigned role permissions — attempting to access unauthorised modules is logged.
3. Complete mandatory training before independent transaction entry.
4. Report system errors, discrepancies, or suspected misuse immediately to their line manager and IT.

2. ORGANISATIONAL STRUCTURE

2.1 Branch Network

Zarewa operates three active sites, each configured as a branch in the ERP:

Kaduna (BR-KD) — Headquarters - Primary sales office and commercial hub - Default workspace branch for new users unless otherwise assigned - Hosts executive functions, procurement HQ, and central pricing administration - Cutting list minimum paid fraction: 70% (configurable in branches table)

Yola Factory (BR-YOL) — Manufacturing - Primary production facility for coil rolling and corrugation - Receives cutting lists from Kaduna sales; dispatches finished goods - Maintains independent coil register, WIP balances, and stock register - GRN posts against procurement POs received at Yola

Maiduguri Factory (BR-MAI) — Manufacturing - Secondary production and distribution point - Same operational modules as Yola - Inter-branch material requests may transfer stock between factories

2.2 Functional Desks

The ERP organises work by functional desk, each mapped to system modules and role permissions:

Desk	System Route	Primary Roles
Sales Office	/sales, /customers	sales_staff, sales_manager
Cashier Desk	/accounts (Desk, Receipts tabs)	cashier
Accounting Desk	/accounting	finance_manager
Procurement	/procurement	md, operations_officer
Operations / Store	/operations	operations_officer
Production Floor	/operations → Production line	operations_officer, production manager
Branch Management	/manager	sales_manager
Executive Office	/exec	md, ceo, chairman
HR Administration	/hr/*	hr_admin, gmhr
Team HR	/team-hr/*	sales_manager (line managers)

Executive HR	/executive-hr/*	md, ceo, chairman
Self-Service HR	/my-profile/*	all staff
Office Administration	/ (Workspace)	all with office.use
System Administration	/settings/*	admin, md (limited)

2.3 Reporting Lines

Operational reporting follows the designation hierarchy encoded in HR:

- **Managing Director** (desig_md) — ultimate approver for high-value transactions, payroll, inter-branch loans, price exceptions
- **Executive Directors** (Operations, Finance, Commercial) — functional oversight within their domains
- **General Manager** (desig_gm) — operational coordination
- **GM HR** (desig_gmhr) — final HR approvals for leave, loans, transfers, exit clearance
- **Branch Manager** (desig_bm, desig_actbm) — branch-level sales, production, refund, and expense approvals
- **Department heads** (Production Manager, Head of Procurement, HR Representative, etc.) — domain-specific supervision

3. ERP SYSTEM ARCHITECTURE

3.1 Technology Stack

Layer	Technology	Purpose
Frontend	React 19 + Vite 8 + Tailwind CSS 4	Single-page application; role-gated routing
Backend API	Node.js + Express 5	REST API with server-side session management
Database	MySQL (production) / SQLite (development)	124+ tables; synchronous write transactions
Authentication	Session cookies + CSRF tokens	bcrypt password hashing; sliding timeout
Shared logic	shared/ directory	Cross-cutting business rules used by API and UI
AI Assistant	Zare (OpenAI/Ollama optional)	In-app coaching, memo polish, operational Q&A
Testing	Vitest (unit) + Playwright (e2e)	Automated workflow

3.2 Deployment Models

Combined deployment (recommended for single-server): - API serves the built React SPA from the same origin - Environment variable: ZAREWA_STATIC_DIR points to frontend dist/ - Simplifies cookie and CSRF handling

Split deployment (CDN + API server): - Frontend on static host; API on VM - Requires VITE_API_BASE, CORS_ORIGIN, and careful cookie SameSite configuration - See docs/SPLIT_DEPLOYMENT_AND_MIGRATION.md

Development stack: - npm run dev:stack — API on port 8787, Vite dev server on 5173 with proxy

3.3 Bootstrap Data Model

On login, the SPA loads GET /api/bootstrap — a filtered workspace snapshot containing branches, permissions, master data, and entity lists the user may see. Additional lazy snapshots load on demand:

- GET /api/workspace/sales-snapshot
- GET /api/workspace/operations-snapshot
- GET /api/workspace/finance-snapshot
- GET /api/workspace/procurement-snapshot

Security note: Bootstrap filtering is a performance convenience, not a security boundary. Every API endpoint enforces requirePermission() independently. Calling an API directly without permission returns 403 even if bootstrap omitted the data.

3.4 Data Scope Rules

Data Type	Scope	Notes
Customers, quotations, receipts, coils, production	Branch-scoped	Filtered by branch_id
Suppliers, transport agents	Company-wide	Shared across all branches
Users, roles, org policy	Company-wide	Admin-managed
GL, treasury (with permission)	Branch or org-wide	hq.view_all_branches for rollup
HR staff profiles	Branch-assigned with org-wide HR access	HR admin sees all
Office threads, work items	Branch or company scope	Depends on record type

4. AUTHENTICATION AND SESSION SECURITY

4.1 Sign-In Procedure

1. Navigate to the Zarewa URL provided by IT (e.g., <https://office.zarewa.com> or local dev URL).
2. Enter **username** and **password**.
3. Optional: use **Google sign-in** if Firebase authentication is configured.
4. On success, the system routes to the role default home (see Master Index Quick-Start table).
5. If `must_change_password` flag is set, the user is forced to set a new password before proceeding.
6. Role training guide modal appears on first successful login after password change.

4.2 Password Policy

Control	Requirement
Minimum length	8 characters
Complexity	At least one uppercase, one lowercase, one digit, one special character
First login	Must change temporary password set by admin
Reset	Admin distributes reset code; token TTL 60 minutes
Storage	bcrypt hashed; plaintext never stored or transmitted in logs

4.3 Session Controls

Control	Default	Environment Variable
Session timeout	120 minutes sliding	SESSION_TIMEOUT_MINUTES (range 5-480)
Failed login lock	5 consecutive failures	FAILED_LOGIN_LOCK_THRESHOLD
Lock duration	30 minutes	ACCOUNT_LOCK_MINUTES
CSRF protection	Required on all mutating requests	Automatic
Activity tracking	POST /api/session/activity extends session	Automatic on user interaction

Account lock recovery: Only Administrator or MD can unlock locked accounts via Settings → Team & access. Branch Managers cannot reset passwords or unlock accounts.

4.4 Workspace Branch Selection

1. Confirm the branch shown in the top workspace bar matches your physical location.

2. Admin, MD, CEO, and Chairman may switch branches or enable “view all branches” for org-wide rollup.
3. All writes (quotations, receipts, GRNs, production jobs) post to the **current workspace branch**.
4. Finance with `finance.cross_branch_post` may post receipts to customers in other branches under controlled rules.

Critical rule: Before posting any financial transaction, verbally confirm branch with a colleague if uncertain. Cross-branch mis-posting requires reversal and re-posting with audit trail.

5. ROLE-BASED ACCESS CONTROL (RBAC)

5.1 Permission Model

The system uses granular string permissions (100+ keys) assigned to roles in `server/auth.js` → `ROLE_DEFINITIONS`. Individual users may receive custom overrides in `app_users.permissions_json`, audited via `org_policy_audit`.

Permission check pattern: `requirePermission('permission.key')` on API routes; `ModuleRouteGuard` and desk-specific guards on frontend routes.

5.2 Complete Role Catalogue

Role Key	Display Title	Permission Summary
admin	System Administrator	* (all permissions)
md	Managing Director	Org-wide strategic control, all approvals, pricing, treasury reserve, executive HR
ceo	Chief Executive Officer	<code>exec.dashboard.view</code> + <code>dashboard.view</code> only — read-only executive
chairman	Chairman (Board)	CEO permissions + <code>hr.chairman.manage</code> for family/scholarship accounts
finance_manager	Accountant / Head of Accounts	Accounting desk, GL, reconciliation, treasury oversight, cross-branch posting
cashier	Cashier	Cashier desk only: receipts confirm, treasury payouts, refund pay — no approve
sales_manager	Branch Manager	Sales, operations, production, refund approve, material incident approve, team HR

sales_staff	Sales Officer	Customers, quotations, receipts post, refund request
operations_officer	Operations Officer / Storekeeper	Inventory, production, deliveries, GRN, material incident create
hr_admin	HR Administrator	Full HR: directory, payroll prep, attendance, discipline, exit
gmhr	GM, Human Resources	Org-wide HR final approvals: leave, loans, transfers, exit clearance
hr_portal_only	HR Portal (Self-Service Only)	Self-service only — mining division / scholarship staff
viewer	Read-Only Viewer	dashboard.view only

Legacy aliases: storekeeper and store_keeper normalise to operations_officer.

5.3 Finance Desk Separation (Phase B)

A core internal control separates Cashier and Accounting desks:

Desk	Route	Required Permission	Capabilities
Cashier Desk	/accounts (cashier tabs)	cashier.desk.view, cashier.receipts.confirm	Receive payments, confirm receipts, process payouts, transfers
Accounting Desk	/accounting	accounting.desk.view	GL journals, trial balance, reconciliation, bank deposits, fixed assets, period close

Enforcement: FinanceDeskRouteGuard in frontend; GL API endpoints reject cashier role; legacy tab RBAC in /accounts.

Rationale: One person must not both receive cash and reconcile the bank account. This satisfies basic segregation of duties for cash handling.

5.4 Module Visibility Matrix

Module / Route	Accessible Roles
/sales	All except hr_portal_only, cashier
/customers	sales_manager, sales_staff, finance_manager, md, admin
/procurement	operations_officer, sales_manager, finance_manager, md, admin
/operations	operations_officer, sales_manager, md, admin
/accounts	finance_manager, cashier, md, admin (BM redirected to /manager)

/accounting	finance_manager, md, admin
/manager	sales_manager, admin
/exec	md, ceo, chairman, admin
/hr/*	hr_admin, gmhr
/team-hr/*	sales_manager
/executive-hr/*	md, ceo, chairman
/my-profile/*	all staff
/reports	finance_manager, sales_manager, md, admin, ceo, chairman
/settings	admin, md (limited)
/edit-approvals	sales_manager, md, admin

6. CROSS-CUTTING BUSINESS RULES

6.1 Approval Thresholds

Configurable under Settings → Governance → Office approval thresholds and org_policy_kv:

Threshold

Expense BM approval limit
Refund MD approval threshold
Credit BM limit
Credit MD required above
High-value receipt double-entry
Others expense finance review
AP3 unclassified alert
Others branch coaching

6.2 Payment and Production Gates

Cutting List Payment Gate: - Default: customer must have paid ≥70% of quotation value before cutting list release - Configurable per branch: cutting_list_min_paid_fraction in branches table - Branch Manager may override with documented justification (approve_production on /manager) - Override logged with approver, note, and paid fraction at time of override

Delivery Payment Gate: - Environment: DELIVERY_PAYMENT_GATE = off | warn | enforce - enforce: delivery blocked until balance cleared or active credit exception exists - ALLOW_MD_DELIVERY_OVERRIDE=true: MD may bypass per delivery - DELIVERY_PAYMENT_GATE_STRICT_FINANCE: finance must confirm before dispatch

Below-Floor Price Gate: - Quotation saves below price list floor are allowed with warning
- Cutting list and production blocked until MD records price exception approval - API:
PATCH /api/quotations/:id/md-price-exception-approve

6.3 Accounting Period Control

- All financial writes enforce assertPeriodOpen() for the posting date's period (YYYY-MM)
- Posting to a closed period returns a hard error
- Period locks managed by finance_manager with period.manage permission
- Back-dated corrections require period to be open or admin override

6.4 Edit Approval System

Changes to confirmed/settled documents require Edit Approval:

1. User attempts edit on locked quotation, PO, customer, or delivery record.
2. System prompts edit approval request.
3. Designated approver (BM or MD) opens /edit-approvals.
4. Approver issues **6-digit one-time code** to requester.
5. Requester enters code → single save is consumed.
6. All actions logged in approval_actions and audit_log.

6.5 Audit Trail Requirements

Every significant mutation writes to audit_log with: - Actor user ID and display name - Timestamp (ISO format) - Action type (e.g., refund.create, receipt.bank_confirmation, material_incident.approve) - Target entity type and ID - Branch ID - Optional JSON payload with before/after values

HR-specific actions additionally log to hr_audit_events. Custom permission changes log to customPermissionAudit.

Audit records are immutable — they cannot be deleted or modified by any user including admin.

6.6 Rate Limiting

Authenticated ledger money POSTs (receipt, advance, refund-advance) are rate-limited per user: - Default: 45 requests per minute - Configure: ZAREWA_LEDGER_POST_MAX, ZAREWA_LEDGER_POST_WINDOW_MS

Login and forgot-password endpoints have separate rate limits to prevent brute force.

6.7 Filing Standards

On approval of payment/refund work items, the system may issue filing reference: ZR/{branch}/{domain}/{year}/{seq} stored in work_item_filing.

Filing completeness (filingCompleteness.js) is checked before work items can be formally closed. Documents without filing numbers cannot be archived.

Print snapshots captured at lock/closure stored in work_item_print_snapshots — protects against retrospective document alteration.

7. ORGANISATIONAL POLICY SETTINGS

Stored in org_policy_kv with full audit trail in org_policy_audit:

Policy Key

CREDIT_BRANCH_MANAGER_LIMIT_NGN
CREDIT_MD_REQUIRED_ABOVE_NGN
DELIVERY_PAYMENT_GATE
ALLOW_MD_DELIVERY_OVERRIDE
DELIVERY_PAYMENT_GATE_STRICT_FINANCE
SESSION_TIMEOUT_MINUTES
FAILED_LOGIN_LOCK_THRESHOLD
ACCOUNT_LOCK_MINUTES
OTHERS_MIN_JUSTIFICATION_LEN
OTHERS_FINANCE_REVIEW_THRESHOLD_NGN
AP3_UNCLASSIFIED_ALERT_THRESHOLD_NGN
OTHERS_BRANCH_COACH_THRESHOLD_PCT
maternityLeaveDays

Changes to org policy require MD or admin authority and are permanently audited.

8. OFFLINE AND DEGRADED MODE

If the API becomes unavailable:

1. UI displays “System offline” banner with last synced workspace data.
2. **No new transactions can be saved** — all write operations queue-fail.
3. User should click “Try reconnect” or refresh after IT confirms server health.
4. **Do not** record transactions on paper intending to “catch up later” without supervisor approval — risk of duplicate posting.
5. IT monitors /api/health, /api/readyz, /api/livez endpoints.

Health endpoint exposes DELIVERY_PAYMENT_GATE mode and other feature flags for operational awareness.

9. IT ADMINISTRATION RESPONSIBILITIES

9.1 User Lifecycle

Action	Procedure	System Location
Create user	Set username, role, branch, temporary password	Settings → Team & access
Reset password	Generate reset code; user changes on next login	Settings → Team & access
Unlock account	Clear lock after failed login threshold	Settings → Team & access
Custom permissions	Grant/revoke individual permission overrides	Settings → Team & access (audited)
Deactivate user	Only after HR exit clearance complete (all 5 stages)	Settings → Team & access

9.2 Database and Migrations

- Migrations run automatically on API startup via server/migrate.js
- Schema defined in server/schemaSql.js with incremental migrations
- Production cutover: set ZAREWA_EMPTY_SEED=1 for clean numbering from 0001
- Backup procedures: see docs/DEPLOYMENT.md \$ Backup and recovery

9.3 Regular Maintenance Schedule

Frequency	Task	Owner
Daily	Confirm server uptime; review failed login attempts in audit log	IT Admin
Weekly	Verify database backup integrity; review session activity	IT Admin
Monthly	Database integrity check; review custom permission changes; verify stock register progress	IT Admin + Finance
Quarterly	Rotate admin credentials; audit	IT Admin + MD

	user access list; test disaster recovery	
Per release	Run npm run test and npm run test:e2e; verify migration success	IT Admin

9.4 Integration API Keys

External systems may read trial balance and journal register via Bearer token: - GET /api/integration/v1/trial-balance - GET /api/integration/v1/journals - Keys managed in Settings; read-only access only

10. ZARE AI ASSISTANT

10.1 Purpose

Zare is the built-in AI assistant providing: - Natural language Q&A on ERP workflows - “Tour this page” step-by-step coaching - Memo drafting and polish (/api/office/ai/polish-memo) - Transaction-specific contextual help - Workflow coaching for blocked actions - Business analysis insights for MD and senior staff

10.2 Usage Rules

1. Zare explains procedures — **you perform every action yourself.**
2. Zare does not post transactions, approve items, or override gates on your behalf.
3. Queries are logged in help_query_log; knowledge gaps in help_knowledge_gaps for improvement.
4. User memory (help_user_memory) and branch memory (help_branch_memory) personalise responses.
5. RAG knowledge base in help_rag_chunks weighted by help_article_weights.

10.3 When to Use Zare vs This Manual

Situation	Use
“How do I post a receipt on this screen?”	Zare — Tour this page
“What is the approval chain for refunds above ₦1M?”	This manual § Segregation table
“Why is my cutting list blocked?”	Zare (reads live quotation state)
Month-end close checklist	This manual + SOP-03
Policy interpretation dispute	Line manager + this manual

11. GLOSSARY (KEY TERMS)

Term	Definition
AP1c	Accounting Phase 1c — revenue recognised at production completion with auto GL
AP2	Accounting Phase 2 — received-basis AP; inventory at landed cost
AP3	Accounting Phase 3 — branch P&L, material costing, payroll labour per job
Bootstrap	Initial workspace data snapshot loaded on login
CL	Cutting List — production work order from sales
COGS	Cost of Goods Sold (GL 5010–5050)
Credit Exception	Formal approval for customer credit terms
CSRF	Cross-Site Request Forgery token required on writes
Delivery Gate	Payment check before goods dispatch
GRN	Goods Received Note — store receipt against PO
OBL	Staff Obligation Account — loans, credits, recoveries
POD	Proof of Delivery — customer sign-off on delivery
RBAC	Role-Based Access Control
WIP	Work-in-Progress — goods in production
Zare	Zarewa AI assistant

Full glossary: [APPENDIX-A-GLOSSARY-AND-REFERENCE.md](#)

End of Part 1. Proceed to department SOPs for operational procedures.